

CONTENTS

Introduction	3
Overview	3
Scope	3
Audience	4
Incident Response Playbook	5
Incident Response Process	5
Preparation Phase	6
Detection & Analysis	10
Containment	14
Eradication & Recovery	15
Post-Incident Activities	16
Coordination	17
Vulnerability Response Playbook	21
Preparation	21
Vulnerability Response Process	22
Identification	22
Evaluation	23
Remediation	24
Reporting and Notification	24
Appendix A: Key Terms	25
Appendix B: Incident Response Checklist	27
Step	27
Incident Response Procedure	27
Action Taken	27
Date Completed	27
Appendix C: Incident Response Preparation Checklist	37
Appendix E: Vulnerability and Incident Categories	39
Appendix F: Source Text	40
Appendix G: Source Text	42

INTRODUCTION

The Cybersecurity and Infrastructure Security Agency (CISA) is committed to leading the response to cybersecurity incidents and vulnerabilities to safeguard the nation's critical assets. Section 6 of Executive Order 14028 directed DHS, via CISA, to “develop a standard set of operational procedures (playbook) to be used in planning and conducting cybersecurity vulnerability and incident response activity respecting Federal Civilian Executive Branch (FCEB) Information Systems.”¹

Overview

This document presents two playbooks: one for incident response and one for vulnerability response. These playbooks provide FCEB agencies with a standard set of procedures to identify, coordinate, remediate, recover, and track successful mitigations from incidents and vulnerabilities affecting FCEB systems, data, and networks. In addition, future iterations of these playbooks may be useful for organizations outside of the FCEB to standardize incident response practices. Working together across all federal government organizations has proven to be an effective model for addressing vulnerabilities and incidents. Building on lessons learned from previous incidents and incorporating industry best practices, CISA intends for these playbooks to evolve the federal government’s practices for cybersecurity response through standardizing shared practices that bring together the best people and processes to drive coordinated actions.

The standardized processes and procedures described in these playbooks:

- Facilitate better coordination and effective response among affected organizations,
- Enable tracking of cross-organizational successful actions,
- Allow for cataloging of incidents to better manage future events, and
- Guide analysis and discovery.

Agencies should use these playbooks to help shape overall defensive cyber operations to ensure consistent and effective response and coordinated communication of response activities

Scope

These playbooks are for FCEB entities to focus on criteria for response and thresholds for coordination and reporting. They include communications between FCEB entities and CISA; the connective coordination between incident and vulnerability response activities; and common definitions for key cybersecurity terms and aspects of the response process. Response activities in scope of this playbook include those:

- Initiated by an FCEB agency (e.g., a local detection of malicious activity or discovery of a vulnerability)
- Initiated by CISA (e.g., a CISA alert or directive) or other third parties, including law enforcement, intelligence agencies, or commercial organizations, contractors, and service providers

The Incident Response Playbook applies to incidents that involve confirmed malicious cyber activity and for which a major incident (as defined by the Office of Management and Budget [OMB] in

¹ [Executive Order \(EO\) 14028: Improving the Nation's Cybersecurity](#)

Memorandum M-20-04² or successor memorandum) has been declared or not yet been reasonably ruled out. The Vulnerability Response Playbook applies to vulnerabilities being actively exploited in the wild. As required by EO 14028, the Director of OMB will issue guidance on FCEB agency use of these playbooks.

Note: these playbooks do not cover response activities that involve threats to classified information or National Security Systems (NSS) as defined by 44 U.S.C.3552(b)(6). See CNSSI1010³ for coordination/reporting guidance for incidents specific to NSS or systems that process classified information.

Audience

These playbooks apply to all FCEB agencies, information systems used or operated by an agency, a contractor of an agency, or another organization on behalf of an agency. It is the policy of the federal government that information and communications technology (ICT) service providers who have contracted with FCEB agencies must promptly report incidents to such agencies and to CISA.⁴

² [Office of Management and Budget \(OMB\) Memorandum M-20-04: Fiscal Year 2019-2020 Guidance on Federal Information Security and Privacy Management Requirements](#)

³ [Committee on National Security Systems](#)

⁴ [EO 14028, Sec. 2. Removing Barriers to Sharing Threat Information](#)

INCIDENT RESPONSE PLAYBOOK

This playbook provides a standardized response process for cybersecurity incidents and describes the process and completion through the incident response phases as defined in National Institute of Standards and Technology (NIST) Special Publication (SP) 800-61 Rev. 2,⁵ including preparation, detection and analysis, containment, eradication and recovery, and post-incident activities. This playbook describes the process FCEB agencies should follow for confirmed malicious cyber activity for which a major incident has been declared or not yet been reasonably ruled out.

- Incident response can be initiated by several types of events, including but not limited to:
- Automated detection systems or sensor alerts
- Agency user report
- Contractor or third-party ICT service provider report
- Internal or external organizational component incident report or situational awareness update
- Third-party reporting of network activity to known compromised infrastructure, detection of malicious code, loss of services, etc.
- Analytics or hunt teams that identify potentially malicious or otherwise unauthorized activity

When to use this playbook

Use this playbook for incidents that involve confirmed malicious cyber activity for which a major incident has been declared or not yet been reasonably ruled out.

For example:

- Incidents involving lateral movement, credential access, exfiltration of data
- Network intrusions involving more than one user or system
- Compromised administrator accounts

This playbook does not apply to activity that does not appear to have such major incident potential, such as:

- “Spills” of classified information or other incidents that are believed to result from unintentional behavior only
- Users clicking on phishing emails when no compromise results
- Commodity malware on a single machine or lost hardware that, in either case, is not likely to result in demonstrable harm to the national security interests, foreign relations, or economy of the United States or to the public confidence, civil liberties, or public health and safety of the American people.

Incident Response Process

The incident response process starts with the declaration of the incident, as shown in Figure 1. In this context, “declaration” refers to the identification of an incident and communication to CISA and agency network defenders rather than formal declaration of a major incident as defined in applicable law and policy. Succeeding sections, which are organized by phases of the IR lifecycle, describe each step in more detail. Many activities are iterative and may continuously occur and evolve until the incident is closed out. Figure 1 illustrates incident response activities in terms of these phases, and Appendix B provides a companion checklist to track activities to completion.

⁵ [NIST Special Publication \(SP\) 800-61 Rev. 2: Computer Security Incident Handling Guide](#)

APPENDIX G: SOURCE TEXT

Agency	Responsibilities	References
Cyber Response Group (CRG)	- Coordinates the development and implementation of the federal government's policies, strategies, and procedures for responding to significant cyber incidents. - Receives regular updates from the federal cybersecurity centers and agencies on significant cyber incidents and measures being taken to resolve or respond to those incidents. - Collaborates with the Counterterrorism Security Group and Domestic Resilience Group when a cross-disciplinary response to a significant cyber incident is required. - Identifies and considers options for responding to significant cyber incidents, and makes recommendations to the Deputies Committee, where higher-level guidance is required. - Coordinates a communications strategy.	- PPD-41 - NCIRP
Cyber Unified Coordination Group (C-UCG)	- Primary mechanism for coordination between and among federal agencies in response to a significant cyber incident as well as for the integration of private sector partners into IR efforts. - The CRG may request the formation of a Cyber UCG. - A Cyber UCG may also be formed when two or more federal agencies* that generally participate in the National Security Council (NSC) Cyber Response Group (CRG) request its formation. *These include relevant Sector Risk Management Agencies (SRMAs). - Identifies and recommends to the CRG, if elevation is required, any additional federal government resources or actions necessary to appropriately respond to and recover from the incident.	- PPD-41 - NCIRP
DHS/CISA	- Lead agency for asset response activities. - Collaborates with industry and government partners to help organizations understand and counter critical infrastructure and cybersecurity risks associated with the malicious activities of nation-state and non-state actors. - Coordinates Government-wide efforts on information security policies and practices; compiles and analyzes agency information security data; develops and conducts targeted operational evaluations, including threat and vulnerability assessments; and hunts for and identifies threats and vulnerabilities within Federal information systems. - Centrally collects and manages FCEB and ICT service provider incident information per EO 14029. - Provides CTI to agencies directly or at scale. When sharing CTI with an agency, or multiple agencies, CISA will communicate with the agency SOC, and depending on the severity, may include the agency CISO along with additional POCs the agency has explicitly designated for the information exchange. - Communicates with the affected FCEB Agencies to understand the nature of the cyber incident or vulnerability. - Disseminates intelligence and information learned during the IR response to other federal agencies for awareness and threat-informed defense. - When sharing at scale, CISA publishes to cisa.gov (such as https://us-cert.cisa.gov/ncas/alerts). Information too sensitive to publish is distributed via alternative avenues into the FCEB space, such as the weekly agency SOC call, HSDN, or classified networks. - Hosts FCEB agency incident coordination call. Provides recommendations on actions, data to collect/check. - Advises FCEB of available resources to assist in response, including CISA, FBI, NSA, and third-party entities. - Upon request, provide analysis, expertise, and other technical assistance to the affected FCEB agency. Available cybersecurity services can be found on page 19 in the CISA service catalog.⁴²	- PPD-41 - CISA Act of 2019 - FISMA (44 USC 3553(b)) - EO 14029 (Secs. 2,6) - NCIRP

⁴² [CISA Services Catalog](#)

Agency	Responsibilities	References
	Available CISA cybersecurity services can be found on page 19 in the CISA service catalog.⁴³	
National Security Agency (NSA)	- Provide intelligence support in response to cyber incidents and vulnerabilities. - Provides attribution information. - Provides technical support upon request. - Provides threat response, asset response and intelligence support to NSS/other systems.	- EO 12333 - NSD-42 - PPD-41

⁴³ [CISA Services Catalog](#)